

DEV-595: Create security checklist for Redis deployments

Department: DevOps

Prepared by: Thanusha Bai V

Date: 17-sept-2026

Task: DEV-587-Redis Security Hardening

1. Executive Summary

This checklist consolidates the findings from DEV-588 through DEV-594 into an actionable, pre-flight and ongoing security checklist for every Glynac Redis deployment. It covers authentication, network hardening, persistence, high availability, monitoring, and disaster recovery. Each item is derived from a tested finding or best practice documented in earlier subtasks. The checklist is designed to be run before go-live, on every deployment, and audited quarterly post-deployment.

2. How to Use This Checklist

Phase	When to run	Owner
Phase A – Pre-deployment	Before provisioning Redis	DevOps engineer
Phase B – Go-live	Before exposing to production traffic	DevOps engineer + reviewer
Phase C – Post-deployment audit	Quarterly, or after any config change	SRE / security reviewer
Phase D – Incident response	After any suspected compromise	On-call + security team

Every checkbox must be ticked (or explicitly waived with sign-off) before the deployment is considered production-ready.

3. Phase A — Pre-Deployment Checklist

3.1 Authentication & Access Control (DEV-588, DEV-590)

- ☐ Default user disabled (ACL SETUSER default off)
- ☐ Dedicated admin user exists with strong password (32+ chars)
- ☐ Admin user's credentials stored in Glynac's secrets manager
- ☐ Each service has its **own** ACL user (no shared credentials)
- ☐ Each service user has a scoped key pattern (~service:*, not ~*)
- ☐ Each service user has a minimal command set – no +@all except admin
- ☐ All non-admin users deny @dangerous (-@dangerous)
- ☐ Channels restricted (resetchannels) unless Pub/Sub is required
- ☐ aclfile configured in redis.conf
- ☐ Password rotation process documented and tested

3.2 Network Hardening (DEV-588)

- ☐ Redis binds to private interfaces only (bind 127.0.0.1 <private-ip>)
- ☐ Redis is **never** bound to 0.0.0.0
- ☐ protected-mode yes
- ☐ Firewall restricts port 6379 to trusted hosts only
- ☐ TLS enabled if traffic crosses untrusted networks (tls-port, port 0)
- ☐ TLS client certificate authentication enabled (tls-auth-clients yes)
- ☐ Unix domain socket considered for local-only consumers

3.3 Dangerous Command Restrictions (DEV-588)

- ☐ DEBUG blocked (default in Redis 8+ – confirm)
- ☐ CONFIG, FLUSHALL, FLUSHDB, KEYS, EVAL denied via ACL for non-admin users
- ☐ SLAVEOF/REPLICAOF denied for non-admin
- ☐ SHUTDOWN denied for non-admin
- ☐ Renamed commands (if used) documented in the runbook

3.4 OS & Host Hardening (DEV-588)

- ☐ Redis runs as **non-root** user (redis)
- ☐ Redis data directory owned by redis:redis with mode 750 or stricter
- ☐ redis.conf mode 640, owned by redis:redis
- ☐ redis.conf contains no plaintext passwords (use aclfile + secrets manager)
- ☐ Host OS patched and CIS-hardened
- ☐ Container (if used) runs with --user non-root, --cap-drop=ALL, read-only rootfs
- ☐ Log rotation configured for Redis logs

3.5 Persistence Configuration (DEV-591)

- ☐ RDB enabled (save 900 1 300 100)
- ☐ AOF enabled (appendonly yes) for sessions/queues/critical data
- ☐ appendfsync everysec (or always for zero-loss)
- ☐ aof-use-rdb-preamble yes
- ☐ auto-aof-rewrite-percentage 100 and auto-aof-rewrite-min-size 64mb
- ☐ Any CONFIG SET followed by CONFIG REWRITE
- ☐ Persistence files survive a restart (verified in staging)

3.6 High Availability (DEV-592)

- ☐ HA strategy chosen (Sentinel or Cluster) and documented
- ☐ Sentinel: 1 master + 2 replicas + 3 Sentinels across separate failure domains
- ☐ Cluster: minimum 3 masters + 3 replicas
- ☐ Failover tested in staging
- ☐ Client library supports chosen HA mode
- ☐ Key design uses hash tags if Cluster migration is on the roadmap

3.7 Backup & Recovery (DEV-593)

- ☐ Backup script exists and is version-controlled
- ☐ Backups include **both RDB and AOF directory**
- ☐ Backups shipped **off-host** (S3/GCS/Azure Blob)
- ☐ Backup retention policy defined (e.g., 7 daily, 4 weekly, 3 monthly)
- ☐ Backups encrypted at rest and in transit
- ☐ **Restore drill performed and documented**
- ☐ Restore procedure includes chown redis:redis and chmod 640/660
- ☐ Backup size sanity check (alert if backup < expected minimum)

3.8 Monitoring & Alerting (DEV-594)

- ☐ Metrics exporter deployed (redis_exporter / Datadog agent / etc.)
 - ☐ Prometheus/Grafana (or equivalent) scraping all Redis nodes
 - ☐ Dashboard created with the 11 panels from DEV-594
 - ☐ Alerts configured for the 20 metrics in DEV-594
 - ☐ Alert routing set up (Critical → pager, Warning → Slack)
 - ☐ Slowlog enabled at 10ms threshold
 - ☐ LATENCY monitor enabled at 100ms
 - ☐ ACL denial metrics (acl_access_denied_*) alerting on spikes
-

4. Phase B — Go-Live Checklist

- ☐ All Phase A items complete
 - ☐ Application connects as its **dedicated service user**
 - ☐ Application passwords loaded from secrets manager (not config files)
 - ☐ Connection pool limits configured and tested
 - ☐ TLS certificate chain verified end-to-end
 - ☐ First backup completed and shipped off-host
 - ☐ Monitoring shows healthy metrics for 30+ minutes
 - ☐ Rollback plan documented
 - ☐ Runbook (backup, restore, failover, incident) linked in deployment ticket
 - ☐ Change recorded in Glynac's change log
-

5. Phase C — Post-Deployment Audit (Quarterly)

Run this every quarter, or after any significant config change.

5.1 Authentication Audit

- ☐ ACL LIST reviewed – no unexpected users
- ☐ No user has nopass
- ☐ No non-admin user has +@all
- ☐ No non-admin user has ~*
- ☐ Passwords rotated within policy window
- ☐ Decommissioned service users removed

5.2 Network Audit

- ☐ CONFIG GET bind still private-only
- ☐ CONFIG GET protected-mode still yes
- ☐ Firewall rules still restrict 6379
- ☐ TLS still enforced (if applicable)

5.3 Persistence & Backup Audit

- ☐ rdb_last_bgsave_status: ok
- ☐ aof_last_write_status: ok
- ☐ aof_last_bgrewrite_status: ok
- ☐ Last 7 backups present in off-host storage
- ☐ **Restore drill performed this quarter**
- ☐ Backup size trend stable (no sudden drops)

5.4 Monitoring Audit

- ☐ All alerts still firing correctly (test with simulated conditions)
- ☐ No alerts silenced without documented reason
- ☐ Slowlog reviewed – no recurring slow commands
- ☐ `acl_access_denied_*` trends reviewed – no unexplained spikes

5.5 Access & Secrets Audit

- ☐ Admin user access log reviewed
 - ☐ Secrets manager entries match Redis users
 - ☐ Terminated employees' credentials revoked
 - ☐ Service account rotation on schedule
-

6. Phase D – Incident Response Checklist

If Redis compromise or unauthorized access is suspected:

- ☐ **Isolate:** firewall-block port 6379 from all hosts
 - ☐ **Preserve evidence:** snapshot ACL LIST, ACL LOG, INFO, and host logs before any change
 - ☐ **Rotate all credentials:** admin + every service user
 - ☐ **Review ACL LOG** for denied commands / failed auth
 - ☐ **Review slowlog** for injected commands
 - ☐ **Check keypace** for unexpected keys
 - ☐ **Check persistence files** – verify no injected writes
 - ☐ **Audit client connections** (CLIENT LIST, INFO clients)
 - ☐ **Rebuild if compromised:** restore from a pre-incident backup, apply all hardening steps from Phase A
 - ☐ **Post-mortem:** document root cause, update this checklist
-

7. Quick Reference – One-Page Pre-Flight

For engineers who want the minimal must-do list before go-live:

AUTH

- ☐ default user off
- ☐ aclfile configured
- ☐ admin + per-service users created
- ☐ passwords in secrets manager

NETWORK

- ☐ bind to private interface
- ☐ protected-mode yes
- ☐ firewall restricts 6379
- ☐ TLS if cross-network

HARDENING

- ☐ non-root user
- ☐ config perms 640
- ☐ dangerous commands denied

PERSISTENCE

- ☐ AOF + RDB enabled
- ☐ CONFIG REWRITE after changes

BACKUP

- ☐ both RDB and AOF backed up
- ☐ shipped off-host
- ☐ restore drill passed

HA

- ☐ Sentinel or Cluster deployed
- ☐ failover tested

MONITORING

- ☐ exporter + Prometheus + Grafana
- ☐ 20 alerts configured
- ☐ slowlog + latency monitor on

8. Summary

Phase	Frequency	Key outcome
A – Pre-deployment	Once per deployment	Ready to go live securely
B – Go-live	Once per deployment	Verified in production
C – Post-deployment audit	Quarterly	Drift detection, compliance
D – Incident response	Ad hoc	Evidence preserved, contained, restored

9. Recommendations for Glynac

- 1. **Adopt this checklist** as the single source of truth for Redis deployments.
- 2. **Version-control it** – checklist evolution tracks Redis version changes.
- 3. **Require sign-off** on Phases A and B before production traffic.
- 4. **Schedule quarterly audits** with a named owner.
- 5. **Review after every incident** – every incident should produce a checklist amendment.
- 6. **Cross-reference each subtask's full report** (DEV-588 through DEV-594) from the checklist for deeper context.

This checklist consolidates findings from DEV-588 through DEV-594 and is validated by the live tests performed throughout the Redis Security Hardening project.

END OF REPORT